

Clase 194 — Deception: honeypots y honeytokens

Parte: **8 — Blue Team, detección y SOC** · Fuente: *The Practice of Network Security Monitoring* — Richard Bejtlich 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Usar el engaño (deception) como fuente de detección de altísima fidelidad: honeypots, honeytokens y cuentas trampa que nadie legítimo debería tocar, de modo que cualquier interacción es, por definición, sospechosa. Aprenderás a desplegar señuelos, a colocar honeytokens en lugares estratégicos y a alertar sobre su uso.

⚠️ **Ética:** los honeypots se despliegan en tu propia infraestructura para observar y alertar. No los uses para atacar a terceros ni para atraer tráfico hacia sistemas que no controlas.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diferenciar** honeypots de baja y alta interacción, honeytokens y honeynets.
2. **Desplegar** un honeypot de laboratorio y recolectar sus eventos.
3. **Colocar** honeytokens (credenciales, archivos, canary tokens) estratégicamente.
4. **Configurar** alertas de alta fidelidad ante cualquier interacción con el señuelo.
5. **Integrar** las señales de deception en el SIEM y el flujo del SOC.

📖 Temas

#	Tema	Por qué importa
1	Deception como estrategia	Señales sin falsos positivos
2	Honeypots de baja vs alta interacción	Riesgo vs riqueza de datos
3	Honeytokens y canary tokens	Trampas ligeras y ubicuas
4	Cuentas y credenciales trampa	Detectar robo y uso de credenciales
5	Honeynets y engaño distribuido	Escalar el engaño
6	Colocación estratégica	Dónde poner el cebo
7	Alertas de alta fidelidad	Priorización automática
8	Riesgos y contención	No convertir el señuelo en punto de apoyo

Definiciones y características

- **Honeypot:** sistema señuelo sin propósito productivo, diseñado para ser sondeado. Característica: toda interacción es sospechosa por definición.
- **Baja interacción:** emula servicios (banners, puertos) sin un SO real. Característica: seguro y fácil, datos limitados.
- **Alta interacción:** SO/servicios reales controlados. Característica: datos ricos, mayor riesgo de ser abusado.
- **Honeytoken:** dato-cebo (credencial, archivo, URL, registro) cuya sola invocación dispara alerta. Característica: no requiere un host dedicado.
- **Canary token:** honeytoken que "avisa" al abrirse (documento, DNS, AWS key). Característica: telemetría de alta fidelidad y despliegue trivial.
- **Cuenta trampa:** usuario de AD atractivo (p. ej. "admin_backup") que nadie debe usar. Característica: cualquier logon con ella es incidente.
- **Honeynet:** red de honeypots interconectados. Característica: observa movimiento lateral del atacante.

Herramientas y preparación

En laboratorio aislado y segmentado:

- **T-Pot** o honeypots individuales (Cowrie para SSH/Telnet, Dionaea para malware).
- **Canarytokens** (proyecto open source de Thinkst) para tokens de documento, DNS y AWS.
- **Cuentas trampa** en tu AD de laboratorio con auditoría de logon.
- Tu SIEM para centralizar las alertas de los señuelos.

Aísla los honeypots del resto de la red para que, si son comprometidos, no sirvan de trampolín.

Laboratorio guiado — Siembra señuelos y escucha

1. **Despliega un honeypot SSH.** Levanta Cowrie en una VM aislada; confirma que registra intentos de login y comandos.
2. **Segmenta.** Coloca el honeypot en una VLAN aislada con salida controlada para que no pueda pivotar.
3. **Genera un canary token.** Crea un documento Word/Excel con Canarytokens y colócalo con un nombre atractivo ("nóminas_2026.xlsx").
4. **Crea una cuenta trampa.** En el AD de laboratorio, añade "svc_backup_admin" con auditoría de logon y sin uso legítimo.
5. **Simula el intruso.** Desde otra VM, sondea el honeypot, abre el documento cebo y usa la cuenta trampa.
6. **Verifica las alertas.** Confirma que cada interacción genera una señal: eventos de Cowrie, aviso del canary token, 4624/4625 de la cuenta trampa.
7. **Integra en el SIEM.** Enruta todas estas señales a una regla de máxima prioridad ("cualquier toque = incidente").
8. **Documenta.** Define el runbook: qué hacer cuando un señuelo dispara (aislar origen, investigar alcance).

Ejercicios

1. Compara honeypot de baja y alta interacción con pros/contras.
2. Diseña la colocación de 3 honeytokens en una red corporativa típica.
3. Crea una cuenta trampa y su regla de alerta de máxima prioridad.
4. Explica por qué las señales de deception tienen tan pocos falsos positivos.
5. Enumera 3 riesgos de un honeypot mal segmentado y su mitigación.
6. Diseña un canary token para detectar acceso no autorizado a un repositorio.

Reto verificable

Despliega al menos dos mecanismos de deception (p. ej. un honeypot y un honeytoken/cuenta trampa) e intégralos al SIEM con alertas de alta prioridad. **Criterio de aceptación:** cada interacción simulada dispara una alerta de máxima prioridad en el SIEM identificando origen y señuelo tocado, y el honeypot está segmentado de forma que no pueda usarse como pivote hacia el resto de la red.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El honeypot se usa como trampolín	Mala segmentación; aíslalo en VLAN sin acceso lateral
Falsos positivos en cuenta trampa	Un escáner de inventario la tocó; excluye esas herramientas o ajusta
Nadie ve las alertas del canary	No integradas al SIEM/notificación; enruta a máxima prioridad
Honeytokens demasiado obvios	Nombres poco creíbles; imita la nomenclatura real de la empresa
Deception olvidada	Señuelos caducan (credenciales rotan); revisa y renueva periódicamente

Preguntas frecuentes

? ¿La deception reemplaza a las detecciones normales? No. Es una capa complementaria de altísima fidelidad. Detecta a quien ya está dentro y explorando, pero no ve todo; se combina con SIEM, EDR y hunting.

? ¿No es peligroso poner un honeypot? Solo si está mal segmentado. Un honeypot aislado, con salida controlada, es seguro. El riesgo aparece cuando puede pivotar hacia la red real.

? ¿Los honeytokens requieren infraestructura? Casi nada. Un canary token es un archivo, una URL o una clave que avisa al usarse. Es de las detecciones más baratas y efectivas que existen.

Referencias

- Bejtlich, R. *The Practice of Network Security Monitoring*. No Starch Press.
- Canarytokens (Thinkst) — <https://canarytokens.org/>
- Cowrie SSH/Telnet honeypot — <https://github.com/cowrie/cowrie>
- T-Pot honeypot platform — <https://github.com/telekom-security/tpotce>
- MITRE Engage (deception framework) — <https://engage.mitre.org/>

Siguiente clase

Clase 195 - Threat intelligence operacional